

# Security+ 1.2 · Gap Analysis

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 1.2 — Gap Analysis (6:44)** · [Vídeo no YouTube ↗](#)

---

**Resumo da Aula:** Análise de lacuna: compara o estado atual (o que tens) vs o desejado (NIST CSF, ISO 27001). A GAP = o que falta. Alimenta o roteiro de melhoria.

## Highlights que a prova cobra

---

- Gap analysis alimenta o risk register
- É a PRIMEIRA etapa de implementação de framework

## Dicas de prova & Cenários Típicos

---

- A prova: 'organization checks its security posture against NIST CSF' = gap analysis

**Cenário clássico de exame:** Cenário típico: 'empresa compara seu estado atual com o NIST CSF pra descobrir o que falta' → gap analysis.

## 🔔 Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Seção 1.2)

**Por que este aprofundamento é cobrado no exame?** O vídeo do Professor Messer (Gap Analysis) resume os conceitos de forma ágil. Contudo, a banca examinadora oficial da CompTIA (SY0-701) exige raciocínio prático de engenharia de segurança, diferenciação entre protocolos concorrentes e aplicação em cenários corporativos reais. Entenda os conceitos complementares fundamentais:

- **Criptografia Simétrica (AES-256, ChaCha20):** Usa uma única chave idêntica para cifrar e decifrar. Excelente para confidencialidade de grandes volumes (BitLocker, banco de dados, túneis VPN). **Atenção de prova:** cifras simétricas NÃO oferecem não-repúdio quando a chave é compartilhada.
- **Criptografia Assimétrica (RSA, ECC, Ed25519):** Usa par de chaves matemáticas: a Chave Pública é distribuída livremente; a Chave Privada é mantida em segredo absoluto pelo titular. Assinar o hash com a chave privada garante **Não-repúdio e Autenticidade**. Cifrar com a chave pública do destinatário garante **Confidencialidade**.
- **Hashing (SHA-256, SHA-3) vs. HMAC:** Hash puro é função matemática unidirecional sem chave, garantindo apenas integridade (qualquer um pode recalculá-lo de um dado adulterado). O HMAC combina hash com chave simétrica secreta, provendo integridade e autenticação mútua entre sistemas conhecidos.
- **TSA (Time Stamping Authority - RFC 3161) e LTV:** Entidade confiável que assina o hash com data/hora auditada, provando o momento exato em que o documento existiu e garantindo validação de longo prazo (LTV) mesmo após a expiração de certificados.

### ⚠️ Armadilhas e Pegadinhas Clássicas da Banca:

- Hash puro NÃO fornece não-repúdio.
- AES com chave compartilhada destrói o não-repúdio.
- Políticas em papel e termos de adesão são controles puramente administrativos; não bloqueiam ataques em tempo de execução.

## ✅ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise dos distratores no fim. Tente responder antes de olhar.

**1. A nova liderança de segurança de uma fintech deseja entender o nível de maturidade da empresa em relação ao NIST Cybersecurity Framework (CSF) para definir o orçamento de cibersegurança do próximo ano. Qual é a avaliação formal indicada para mapear a situação atual versus os requisitos do framework?**

- A)** Gap Analysis (Análise de Lacunas)
- B)** Scan de portas com Nmap
- C)** Teste de intrusão do tipo Red Team
- D)** Auditoria de desempenho de rede

**2. Qual é a principal saída (entregável) produzida ao término de um processo de Gap Analysis?**

- A)** Um plano de ação e remediação priorizado para alcançar a conformidade
- B)** A demissão dos funcionários que cometeram erros operacionais
- C)** A compra imediata de ferramentas caras sem estudo prévio
- D)** Um certificado de imunidade a ataques cibernéticos

**3. Uma empresa que processa pagamentos com cartão de crédito precisa se adequar ao PCI DSS v4.0. Ao realizar a Gap Analysis, a equipe constata que senhas de contas de serviço não são rotacionadas automaticamente. Esse achado representa:**

- A)** Um 'gap' (lacuna de controle) de conformidade que deve ser remediado
- B)** Um controle compensatório aprovado
- C)** Um falso positivo irrelevante para a auditoria
- D)** Uma violação que dispensa qualquer ação se o firewall estiver ativo

**4. Qual é a diferença primordial entre uma Avaliação de Vulnerabilidades (Vulnerability Assessment) e uma Análise de Lacunas (Gap Analysis)?**

- A)** A análise de vulnerabilidades busca falhas técnicas em sistemas (softwares/portas); a Gap Analysis compara processos e políticas a normas e padrões de segurança
- B)** A Gap Analysis só analisa código-fonte; a análise de vulnerabilidades só analisa contratos
- C)** Ambas são idênticas e rodam as mesmas ferramentas de varredura
- D)** A Gap Analysis é feita exclusivamente por invasores externos

**5. Ao conduzir uma Gap Analysis contra o framework ISO/IEC 27001, qual é o papel da Declaração de Aplicabilidade (Statement of Applicability - SoA)?**

- A)** Documentar quais controles do Anexo A são aplicáveis à empresa e justificar a exclusão dos demais
- B)** Listar todos os endereços IP dos servidores da empresa
- C)** Descrever o algoritmo de criptografia do banco de dados
- D)** Registrar o contrato de trabalho dos administradores

**6. Durante uma Gap Analysis, a equipe de segurança descobre que uma política exige autenticação de dois fatores para todos os funcionários, mas o departamento comercial usa apenas usuário e senha há mais de um ano. Isso evidencia uma lacuna de:**

- A)** Implementação e conformidade operacional (a política existe no papel, mas não é aplicada na prática)
- B)** Falta de documentação gerencial
- C)** Falha de hardware no servidor de banco de dados
- D)** Incompatibilidade com leis trabalhistas

**7. Em que momento do ciclo de vida de implementação de um programa de segurança da informação a Gap Analysis deve ser prioritariamente executada?**

- A)** Na fase inicial de planejamento e diagnóstico, antes de adquirir novas soluções
- B)** Apenas após um ataque cibernético de grandes proporções
- C)** No encerramento definitivo das operações da empresa
- D)** Exclusivamente antes de contratar estagiários

**8. Qual indicador de maturidade é frequentemente empregado em relatórios de Gap Analysis para mensurar a evolução dos processos de segurança da organização?**

- A)** CMMI (Capability Maturity Model Integration) com níveis de 1 a 5
- B)** Tamanho do arquivo de log em Gigabytes
- C)** Número de e-mails recebidos pela diretoria
- D)** Velocidade de download da conexão de fibra

**9. Um relatório de Gap Analysis identificou 45 lacunas de segurança. Como o CISO deve priorizar o plano de remediação perante o conselho executivo?**

- A)** Baseando-se no impacto de risco para o negócio, probabilidade de ocorrência e requisitos regulatórios mandatórios
- B)** Remediando apenas as tarefas mais fáceis e rápidas primeiro
- C)** Pelo custo mais alto das ferramentas disponíveis no mercado
- D)** Em ordem alfabética do nome dos departamentos afetados

**10. Uma empresa adquire uma startup concorrente. Antes de conectar as duas redes corporativas, o time de segurança realiza uma Gap Analysis mútua. Qual o objetivo dessa medida de diligência prévia (Due Diligence)?**

- A)** Identificar fragilidades de segurança da empresa adquirida que poderiam comprometer a rede compradora
- B)** Reduzir o salário dos engenheiros da startup
- C)** Instalar spyware para monitorar as conversas da equipe adquirida
- D)** Apagar o histórico de e-mails da empresa adquirida

## GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

### 1) A — Gap Analysis (Análise de Lacunas).

✓ **Por que está certa:** A Gap Analysis compara o estado atual da postura de segurança da organização com um padrão, regulamentação ou framework de referência desejado, identificando as lacunas (gaps) que precisam ser preenchidas.

✗ **Por que as outras estão erradas:**

- *Scan de portas com Nmap:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Teste de intrusão do tipo Red Team:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Auditoria de desempenho de rede:* Cifra legada com tamanho de chave/bloco insuficiente e vulnerável a quebras práticas modernas (como Sweet32 e ataques de fluência).

### 2) A — Um plano de ação e remediação priorizado para alcançar a conformidade.

✓ **Por que está certa:** O entregável central da Gap Analysis é um relatório de discrepâncias acompanhado de um plano de ação (roadmap de remediação) priorizado por criticidade e risco para fechar as brechas encontradas.

✗ **Por que as outras estão erradas:**

- *A demissão dos funcionários que cometeram erros operacionais:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *A compra imediata de ferramentas caras sem estudo prévio:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Um certificado de imunidade a ataques cibernéticos:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

### 3) A — Um 'gap' (lacuna de controle) de conformidade que deve ser remediado.

✓ **Por que está certa:** Qualquer divergência entre a exigência mandatória do framework (PCI DSS) e a prática operacional real da empresa constitui uma lacuna de controle (gap).

✗ **Por que as outras estão erradas:**

- *Um controle compensatório aprovado:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Um falso positivo irrelevante para a auditoria:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Uma violação que dispensa qualquer ação se o firewall estiver ativo:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

### 4) A — A análise de vulnerabilidades busca falhas técnicas em sistemas (softwares/portas); a Gap Analysis compara processos e políticas a normas e padrões de segurança.

✓ **Por que está certa:** Vulnerability Assessment é técnica e automatizada (procura bugs e patches faltantes). Gap Analysis é estratégica e holística (compara pessoas, processos, governança e controles técnicos contra um padrão formal).

✗ **Por que as outras estão erradas:**

- *A Gap Analysis só analisa código-fonte; a análise de vulnerabilidades só analisa contratos:* Cifra

legada com tamanho de chave/bloco insuficiente e vulnerável a quebras práticas modernas (como Sweet32 e ataques de fluência).

- *Ambas são idênticas e rodam as mesmas ferramentas de varredura*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *A Gap Analysis é feita exclusivamente por invasores externos*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

#### **5) A — Documentar quais controles do Anexo A são aplicáveis à empresa e justificar a exclusão dos demais.**

✓ **Por que está certa:** O SoA na ISO 27001 documenta formalmente quais controles de segurança são necessários para o contexto da organização e a justificativa para qualquer controle não adotado.

#### **✗ Por que as outras estão erradas:**

- *Listar todos os endereços IP dos servidores da empresa*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Descrever o algoritmo de criptografia do banco de dados*: Cifra legada com tamanho de chave/bloco insuficiente e vulnerável a quebras práticas modernas (como Sweet32 e ataques de fluência).
- *Registrar o contrato de trabalho dos administradores*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

#### **6) A — Implementação e conformidade operacional (a política existe no papel, mas não é aplicada na prática).**

✓ **Por que está certa:** Uma das maiores causas de gap é a discrepância entre a política escrita (managerial) e a execução real pelos usuários (operational/technical).

#### **✗ Por que as outras estão erradas:**

- *Falta de documentação gerencial*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Falha de hardware no servidor de banco de dados*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Incompatibilidade com leis trabalhistas*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

#### **7) A — Na fase inicial de planejamento e diagnóstico, antes de adquirir novas soluções.**

✓ **Por que está certa:** A Gap Analysis é o passo zero do planejamento: ela estabelece o baseline e a linha de base sobre onde a empresa está versus onde ela precisa chegar.

#### **✗ Por que as outras estão erradas:**

- *Apenas após um ataque cibernético de grandes proporções*: Cifra legada com tamanho de chave/bloco insuficiente e vulnerável a quebras práticas modernas (como Sweet32 e ataques de fluência).
- *No encerramento definitivo das operações da empresa*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

- *Exclusivamente antes de contratar estagiários*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

#### **8) A — CMMI (Capability Maturity Model Integration) com níveis de 1 a 5.**

✓ **Por que está certa:** Modelos como CMMI avaliam o nível de maturidade dos processos de segurança (do nível 1: inicial/ad-hoc ao nível 5: otimizado).

✗ **Por que as outras estão erradas:**

- *Tamanho do arquivo de log em Gigabytes*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Número de e-mails recebidos pela diretoria*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Velocidade de download da conexão de fibra*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

#### **9) A — Baseando-se no impacto de risco para o negócio, probabilidade de ocorrência e requisitos regulatórios mandatórios.**

✓ **Por que está certa:** A priorização estratégica deve ser baseada em Gestão de Riscos (matriz de impacto x probabilidade) e conformidade legal estrita (compliance).

✗ **Por que as outras estão erradas:**

- *Remediando apenas as tarefas mais fáceis e rápidas primeiro*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Pelo custo mais alto das ferramentas disponíveis no mercado*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Em ordem alfabética do nome dos departamentos afetados*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

#### **10) A — Identificar fragilidades de segurança da empresa adquirida que poderiam comprometer a rede compradora.**

✓ **Por que está certa:** A Gap Analysis em processos de fusões e aquisições (M&A due diligence) assegura que vulnerabilidades da rede adquirida não se tornem vetores de invasão lateral para a controladora.

✗ **Por que as outras estão erradas:**

- *Reduzir o salário dos engenheiros da startup*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Instalar spyware para monitorar as conversas da equipe adquirida*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Apagar o histórico de e-mails da empresa adquirida*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

